

john@2600:~/IT-OT/TD3\$

GOUVERNE SOUS ATTAQUE

Cybersécurité des systèmes industriels – TD3

Analyse · Attaque · Détection d'une plateforme OT/ICS

John – École 2600

01 / LA PLATEFORME

Un système de **gouverne navale** simulé sur 5 VMs :

- **NTP** – référence de temps
- **PLC** – automate, contrôle la partie opérative
- **CC** – pont commande ↔ supervision
- **SCADA** – visualisation du procédé
- **Attacker** – le poste offensif

Deux réseaux : host-only (supervision) et interne (commande). Le CC est le seul pont.

02 / COMPORTEMENT MÉTIER NOMINAL

Le SCADA émet un **ordre de barre** qui balaie la plage **0-80**.
Le gouvernail **suit fidèlement** l'ordre.

l_rub	r_rub	order	phy_l	phy_r
26	26	27	26	26
28	28	29	28	28
31	31	31	31	31

Invariant métier : le gouvernail suit l'ordre.

C'est lui que l'attaque va briser – et lui qui fondera la détection.

03 / MÉTHODE – VOIR L'INVISIBLE

Le dialogue **PLC** ↔ **CC** est sur le réseau interne, invisible de l'hôte.

Astuce : le CC a une patte sur **chaque** réseau → on trace ses 2 NICs au niveau de l'hyperviseur (**sans root**) :

```
VBoxManage controlvm CC nictrace1 on    # côté PLC  
VBoxManage controlvm CC nictrace2 on    # côté SCADA / Attacker
```

tshark + dissecteur Modbus, corrélé au téléservice JSON.

04 / LE PONT – CC

Le **CC** expose deux surfaces **non authentifiées** sur le réseau supervision :

- un **serveur Modbus/TCP** (port 502)
- une **API web** FastAPI (`/openapi.json` le confirme) :

Route	Effet
<code>/</code>	téléservice JSON
<code>/attack?plc&choice&offset</code>	manipule le procédé
<code>/restore?plc</code>	annule

05 / L'ATTAQUE IDENTIFIÉE

Au lancement de la VM **Attacker** (**.15.4**), une seule requête :

```
192.168.15.4 → 192.168.15.1  
GET /attack?plc=gouv&choice=1&offset=10
```

La capture *exhaustive* corréle le clic HTTP à l'écriture Modbus dans le PLC,
18 ms plus tard :

t+0	.15.4 → CC	GET /attack?plc=gouv&choice=1&offset=10
t+18ms	CC → PLC	FC6 reg198 = 10 (offset)
t+21ms	CC → PLC	FC6 reg196 = 1 (choice)

- **Cible** : le **PLC**, via les registres **196/198** (≠ ordre reg 40)
- Le gouvernail **se fige** ; ni exploit, ni authentication

06 / SCÉNARIOS MIS EN ŒUVRE

Reproduits et restaurés entre chaque essai :

- **A – Gel du gouvernail** (`choice=1` en boucle) → **perte de gouverne**
- **B – Fausses données** (`choice=2`) → divergence ordre/valeur, et **débordement entier** : la valeur remonte à **65510**
- **C – Injection Modbus** : write `FC6` reg40 → `order_rub` usurpé, sans authentification

07 / L'ATTAQUE SECTIONNE LA BOUCLE

Effet réseau majeur : sous attaque, le brin **CC → PLC** s'éteint.

État	Trafic Modbus CC ↔ PLC
Nominal	2816 trames / 152 s (scrutation + ordre relayé)
Sous attaque	5 trames / 3740 s – boucle morte

Le gouvernail garde sa **dernière valeur relayée** → barre qui ne répond plus.
(La SCADA, elle, continue d'écrire l'ordre sur le CC : seul CC → PLC est coupé.)

08 / DÉTECTION – D'ABORD LE MÉTIER

```
# D1 : rupture de corrélation ordre / gouvernail
if abs(order_rub - phy_l_rub) > SEUIL and persiste(3s):
    alerte("manipulation de la gouverne")

# D7 : heartbeat de la boucle de commande
if taux_scrutation(CC_vers_PLC, 10s) < SEUIL_MIN:
    alerte("relais CC<->PLC sectionné")    # détecte le gel à la source
```

- **réseau** : write Modbus hors-SCADA (reg 40/196/198), HTTP `/attack`, hôte non inventorié.

09 / RECOMMANDATIONS

1. **Retirer** `/attack` & `/restore` ; téléservice en lecture seule + auth
2. **Segmenter** : le CC filtre 502 ↔ SCADA seulement (pare-feu OT / diode)
3. **Sécuriser Modbus** : TLS / ACL + contrôle de plage (barre $\in [0,80]$)
4. **Détection métier** industrialisée (corrélation ordre/gouvernail)
5. **Mode dégradé maîtrisé** : rejeter une consigne incohérente plutôt que figer
6. **Inventaire / NAC** sur les segments OT

john@2600:~/IT-OT/TD3\$

SANS EXPLOIT, SANS AUTH

Un simple appel HTTP prive le navire de gouverne.
La défense la plus robuste connaît le procédé.

John – École 2600 • IT-OT TD3